

Next-Gen Secure Access Using Intelligent Zero Trust Network Architecture

1st Dr. Vinod Desai

Computer Science and Engineering
Sai Vidya Institute of Technology
Bangalore, India
vinod.desai@saividya.ac.in

2nd Sowmya H N

Computer Science and Engineering
Sai Vidya Institute of Technology
Bangalore, India
sowmya.hn@saividya.ac.in

3rd Suprit U

Computer Science and Engineering
Sai Vidya Institute of Technology
Bangalore, India
supritu.22cs@saividya.ac.in

4th Kushaal A Kumar

Computer Science and Engineering
Sai Vidya Institute of Technology
Bangalore, India
kushaalakumar.22cs@saividya.ac.in

5th Bhoomika C

Computer Science and Engineering
Sai Vidya Institute of Technology
Bangalore, India
bhoomikac.22cs@saividya.ac.in

6th Chandana U

Computer Science and Engineering
Sai Vidya Institute of Technology
Bangalore, India
chandana.22cs@saividya.ac.in

Abstract—Modern cybersecurity encounters considerable obstacles owing to the limitations of perimeter-based defenses in distributed computing settings. This study explores Zero Trust Network Access as a holistic framework that removes implicit trust within networks through continuous identity verification and context-aware policy enforcement. Key principles such as explicit user authentication, restricted permission distribution, and detailed control mechanisms are evaluated against recognized industry standards. The practical application is illustrated through a modular system that employs React for client-side interfaces and Bun/Node.js for server-side operations. Instead of building a proprietary identity infrastructure, the design integrates Zitadel through containerized deployment to oversee authentication processes, permission management, policy governance, and multifactor authentication. Additional contextual protections at the application level augment Zitadel's inherent functionalities by implementing IP filtering, geographic validation, and tailored policy logic. Findings reveal that identity-focused architectures significantly reduce exposure risks, enhance operational visibility, fortify governance structures, and facilitate dynamic authorization within distributed systems. Insights from the implementation highlight potential for improved scalability, intelligent anomaly detection via machine learning, thorough risk assessment, and adaptable deployment strategies appropriate for enterprise-level Zero Trust implementation.

Index Terms—Zero Trust Network Access, cybersecurity frameworks, identity governance, enforcement of minimal privilege, adaptive verification, access control driven by policy, Zitadel platform

I. INTRODUCTION

The expansion of cloud infrastructure, mobile endpoints, and workforces that are geographically dispersed has exposed fundamental vulnerabilities in traditional perimeter-centric security models that rely on the assumption of internal network trust. Current threat environments illustrate that organizational boundaries are becoming increasingly fluid, with malicious activities arising from both external sources and compromised internal assets, thus making static trust frameworks inadequate for safeguarding.

In contrast to traditional virtual private network systems, Zero Trust Network Access removes the assumption of trust by requiring ongoing verification for all users, devices, and application components through context-aware assessments. The core principles include minimal privilege distribution, identity-centric enforcement strategies, and adaptive policy frameworks that collectively limit attack surfaces and prevent unauthorized lateral movement within systems.

This study introduces fundamental Zero Trust concepts along with a practical prototype that illustrates these principles through implementation. The experimental setup utilizes Zitadel, which is deployed via Docker containerization, to manage identity administration, authentication processes, authorization decisions, and multifactor authentication. Additionally, it incorporates supplementary controls for IP-based restrictions, geographic validation, and policy enforcement through a custom React frontend integrated with Bun/Node.js backend services, extending the application of Zero Trust methodologies.

This contribution merges established Zero Trust strategies with practical implementation, providing a coherent yet effective demonstration of how Zero Trust principles can be applied to modern application infrastructures.

II. LITERATURE REVIEW

Security based on zero trust has become common because older methods relying on fixed boundaries no longer work well [1], [2], [3], [4], [5], [11]. While past systems treated inside traffic as safe by default, this model checks identity constantly instead. Minimal permissions are granted at any time due to built-in restrictions. Because of tight controls, lateral spread by attackers faces more obstacles [1], [4], [6].

Starting with NIST SP 800-207, a baseline emerges for Zero Trust through clear definitions of key elements [1]. Though built on similar ideas, real-world cases from companies like Cloudflare and Zscaler show varied ways to apply the model

[2], [3], [4], [5], [23], [24], [25]. Where scalability matters most, consistent policy control becomes essential across systems. Instead of assuming trust, verifying user identities shapes how access is managed. Working across mixed setups - on-premise plus cloud - introduces specific hurdles. Secure links to cloud resources remain central, regardless of network design. Even when environments differ, focusing on these areas supports reliable outcomes.

Though often linked to Zero Trust, microsegmentation gains strength when networks split into tight, separated zones - this slows attackers moving sideways inside systems [6], [7], [8], [10]. Instead of broad perimeters, Microsoft points to blending Zero Trust with SASE frameworks, where live data shapes access rules through artificial intelligence [9]. Protection now shifts based on behavior, not just fixed boundaries.

Access controls sit at the heart of Zero Trust models. Through FastAPI, features such as authentication steps, role limits, or token management emerge plainly in real use [12], [13], [14]. Following closely, TOTP introduces added security - short-lived passcodes that verify who users are with greater confidence [20], [21], [22]. Where someone logs in from, together with context-driven policies, influences how strictly access gets enforced [19].

Behavioral analytics and anomaly detection can be considered vital in determining any threats from insiders and unusual user behavior. Some of the examples of the platforms that apply behavioral analysis in anomaly detection are Securonix, CrowdStrike, Zscaler, and Splunk [15], [16], [17], [18]. Though less emphasized, studies into spotting unusual patterns point toward smarter tools learning from new threats. These methods increasingly rely on machines that adjust themselves when faced with evolving risks online [26], [27].

Though current research highlights how Zero Trust paired with microsegmentation strengthens defenses, integration of behavioral analytics often remains uneven across setups. Where secure authentication is applied alongside hybrid cloud measures, resilience improves - yet reliance on fixed rules persists in practice. Centralized oversight continues to dominate despite openings for self-driven systems. Some models adapt faster than others when threats shift unexpectedly.

III. SYSTEM DESIGN

Fig.1 illustrates the system's design, built on a Zero Trust model with Zitadel managing identities and permissions. Rather than depend on conventional VPN methods, each attempt to enter undergoes constant confirmation via login checks, access rules, and enforced policies. From another angle, the interface made with React connects to a backend running on Bun or Node.js - this layer evaluates surroundings like location data and network addresses before granting entry. To keep messages safe between parts, OpenID Connect and OAuth 2.0 form the backbone of exchange protocols. Scattered throughout are independent modules handling protection tasks: encoding data, tracking events, processing patterns with machine learning, and stretching across cloud platforms without losing grip on safety controls.

A. System Architecture Overview

At the system level, the architecture consists of layered modules that are tasked with authentication, authorization, policy enforcement, geographic verification, logging, and contextual validation, incorporating Zitadel integration throughout. Zitadel, which operates through Docker, provides identity management, multifactor authentication, token handling, and federated login functionalities.

All user interactions are authenticated using OpenID Connect and OAuth 2.0 standards, which facilitate secure token-based communication between client and server components. The React frontend and Bun/Node.js backend enhance Zitadel's security measures with supplementary policies for IP-based filtering and location-aware validation. This identity-centric approach is in accordance with Zero Trust principles, shifting access control from static credentials to a dynamic, context-driven evaluation.

B. Design Rationale

1) *Modularity*: The system adheres to modular design principles, ensuring that authentication, authorization, policy verification, and contextual validation are distinct yet interoperable components. Zitadel's application programming interfaces facilitate seamless integration of identity services without a strong dependency on application logic. This modular framework allows for the independent updating, replacement, or scaling of components without causing disruptions across the entire system. It accommodates integration with a variety of architectures, enabling different deployments to align with organizational operational or regulatory needs for the implementation of Zero Trust.

2) *Security Enhancements*: Zitadel enhances system security by implementing modern authentication protocols such as OpenID Connect, OAuth 2.0, and optional multifactor and passwordless authentication. Tokens, identity claims, and sensitive information are encrypted both during transmission and while stored. The backend system utilizes additional contextual validation methods, including IP and geographic checks, to improve access decision-making and enforce more stringent controls. Ongoing audit logging facilitates traceability, meets compliance standards, and aids in forensic analysis following incidents.

3) *Contextual Control and Verification*: The system conducts contextual verification, which encompasses user role validation, IP range verification, and geographic filtering, to improve Zero Trust access determinations. Each incoming request is evaluated against identity claims issued by Zitadel and local policy rules established in the backend. A default-deny strategy guarantees that access is granted solely when all contextual and identity criteria are met.

4) *Reduced Attack Surface and Intelligent Routing*: By employing ephemeral, identity-specific tokens instead of enduring credentials, Zitadel effectively reduces the risks associated with credential exposure. The enforcement of centralized policies inhibits unauthorized lateral movement among application components. Together, these strategies diminish the overall

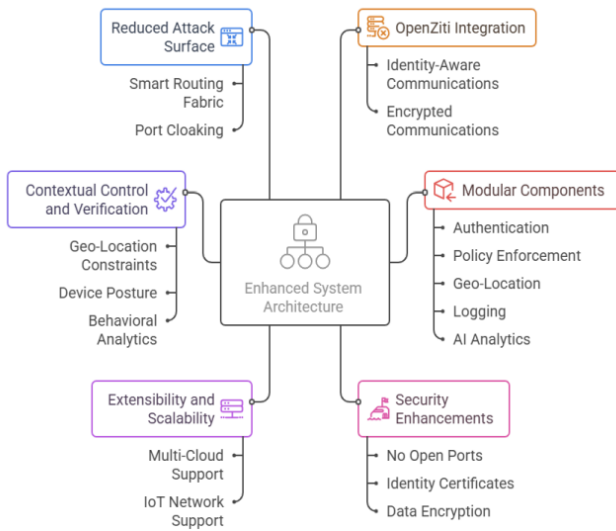


Fig. 1. Enhanced system architecture demonstrating OpenZiti integration with modular components including contextual control, security enhancements, and extensibility features

attack surface and guarantee that access decisions are strictly regulated by identity and context.

5) *Integration Advantages*: The integration offers numerous advantages: centralized identity management facilitates cohesive administration of users, tokens, roles, and policies; robust authentication through multifactor and passwordless techniques improves account security; context-aware authorization permits access rules to adjust dynamically according to IP address, location, and role; flexible deployment functions across cloud, on-premises, and edge environments utilizing Docker; Zero Trust alignment mandates verification at each stage and reduces the likelihood of unauthorized access.

IV. METHODOLOGY

Shown in Fig.2, the method applies a Zero Trust Network Access model, relying on Zitadel to manage identities securely. Rather than depend on perimeter defenses, each user request undergoes ongoing verification via OpenID Connect, OAuth 2.0, PKCE, along with short-lived JWT tokens. Security rules like IP restrictions, geographic validation, and role-defined permissions are applied by the React interface paired with a Bun/Node.js server layer. Private gateways enable protected links to cloud systems, internal networks, and web tools - using encryption throughout the path.

A. System Initialization

The foundational Zero Trust Network Access environment was created by implementing Zitadel through its official Docker configuration. This approach streamlines the initialization process, as the identity provider, administrative console, and database function within separate containers. After deploying the Zitadel instance, the backend was set up to interact with Zitadel via OAuth 2.0 and OpenID Connect endpoints. The React frontend leveraged Zitadel's software development kit to

initiate authentication requests using Authorization Code Flow with Proof Key for Code Exchange, ensuring secure token retrieval from the browser environment. All communications with Zitadel are conducted over HTTPS; sensitive credentials are never transmitted through the client application. This practice is consistent with Zero Trust principles, emphasizing minimal implicit trust and decreased exposure.

B. Identity Registration and Enrollment

Within Zitadel, both users and applications are registered as distinct identities. Each identity is endowed with specific permissions or roles, which may include administrator, user, and restricted user; projects and applications delineate the permitted scopes; and various authentication methods such as passwordless login, multifactor authentication, or Time-based One-Time Password authentication are employed. Upon user authentication, the React application redirects users to the login interface hosted by Zitadel. Zitadel then authenticates the user and issues short-lived tokens, which include an ID Token that contains verified identity claims, an Access Token that facilitates backend API access, and a Refresh Token that the backend uses to securely obtain new access tokens. All tokens issued by Zitadel are signed with its private keys, which allows for backend verification without the necessity of contacting Zitadel for each request.

C. Policy and Access Configuration

Zero Trust access control was established through a dual-layer approach. Zitadel's policies encompass role-based access control, permission sets at both the organization and project levels, rules enforcing multifactor authentication, and login regulations that address passwordless authentication, Time-based One-Time Passwords, and accounts that have been disabled. Within the Node.js backend, application-level policies implement contextual regulations that include IP restrictions to prevent access from dubious regions, geolocation verifications, validation of user roles based on JSON Web Token claims, as well as checks for session expiration and token integrity. Each request adheres to a default-deny framework, indicating that access is prohibited unless it is explicitly confirmed through identity and contextual validation.

D. Deployment of Service and Secure Communication

The Authorization Code Flow with Proof Key for Code Exchange enables secure interactions between the React frontend and the Bun/Node.js backend. This method is considered the most secure for single-page applications, as the Proof Key for Code Exchange safeguards against code interception, ensures that no client secret is stored within the browser, and allows for the exchange of authorization codes only after verifying proof of possession.

All tokens are based on encrypted JSON Web Tokens that are signed, have a short lifespan, and are tied to both session and user identity. Zero Trust API requests transmit the Access Token in the Authorization header, accompanied by additional metadata such as the IP address and timestamp. The

backend authenticates the provided tokens by examining JSON Web Token signatures, confirming scopes and roles, validating expiration and issuer, and aligning context rules with respect to IP and location. Only after these verifications can access to protected resources or application programming interfaces be granted.

E. Monitoring and Log Analysis

Logging was set up at both the identity and application levels. Zitadel logs document authentication attempts, the status of multifactor authentication, token issuance, and any changes in administrative roles. Backend logs track API access attempts, failures in JSON Web Token validation, mismatches in IP and geolocation, as well as patterns of suspicious requests. These logs underwent manual analysis and were exported for offline examination to prevent the exposure of sensitive operational information. The insights derived from this analysis assist in identifying anomalies such as unauthorized access attempts, unusual login locations, and the misuse of expired tokens.

F. Security and Extensibility Considerations

Security begins by trusting nothing automatically, checking every access attempt carefully. A user logs in through a method that keeps codes private, making stolen data less useful. Tokens last only briefly, so old ones stop working fast if leaked. Keys renew on their own before they can be compromised easily. Logging in needs more than one proof of identity each time. Location checks confirm whether login attempts match usual patterns. Strange network addresses raise flags immediately during verification. Accounts shut down temporarily after too many failed tries. Out in the open, the setup uses Docker containers to scale smoothly plus stay steady across deployments. Instead of hanging on to permanent keys, it trims risks by checking every request with tight token rules. Tokens get a full look - validity, purpose, lifespan - before any door opens. Access only follows after backend checks confirm everything lines up right. From start to finish, it keeps guard up by adjusting access on the fly, tied to who you are. Protection sticks around, no matter where connections come from. Each check learns from the moment before, building trust without relying on network walls.

V. EXPERIMENTAL RESULTS

Looking at Fig.3, differences in how systems handle login and permission checks become clear when comparing old setups, zero trust networks, and those using artificial intelligence. While older approaches depend heavily on static credentials and boundary defenses, their ability to respond fades under modern threats. Instead, Zero Trust Network Access adjusts permissions dynamically, verifies users constantly, and accounts for device status during each session. With machine learning tools added into decision workflows, unusual actions are spotted faster - leading to smarter choices about who gets access and when it should be blocked.

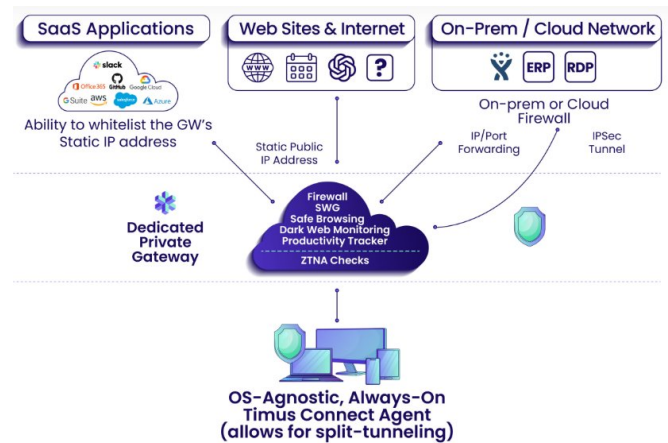


Fig. 2. Deployment architecture illustrating dedicated private gateway with ZTNA checks, firewall security, and OS-agnostic agent connectivity

Access Control Mechanisms (Authentication vs. Authorization)

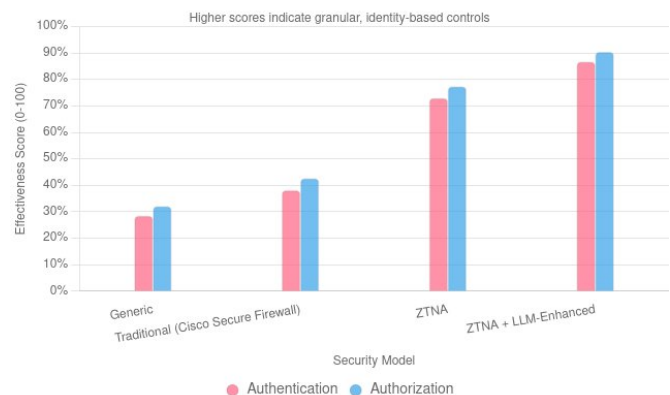


Fig. 3. Comparative effectiveness of authentication and authorization mechanisms across security models from generic to LLM-enhanced ZTNA

Network Visibility & User Activity Insights (Visibility vs. Activity Insights)

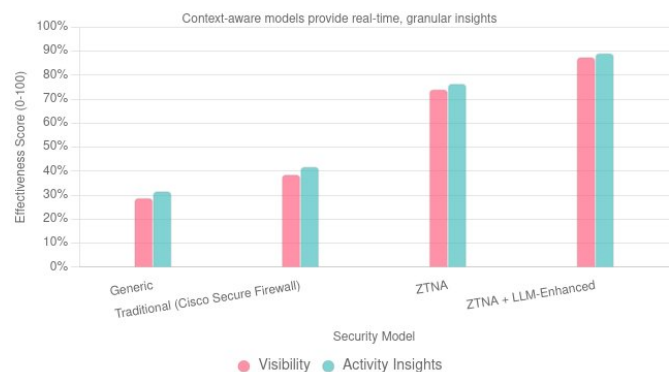


Fig. 4. Progressive enhancement in network visibility and user activity insights across security models demonstrating real-time monitoring capabilities

Fig.4 shows clearer insights into network traffic once ZTNA and smart security tools are in place. Old-style defenses strug-

Threat Detection Capabilities (Detection Rate vs. Response Time)

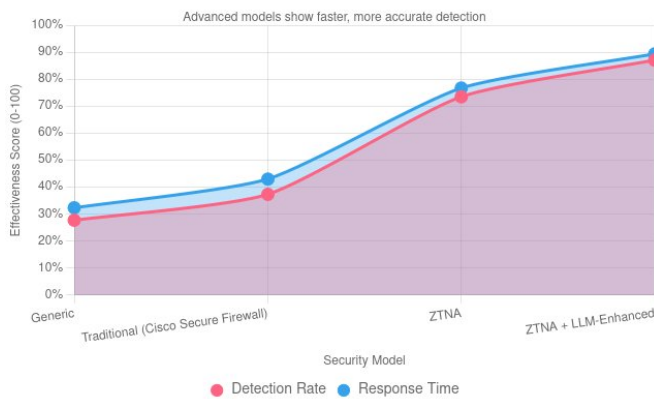


Fig. 5. Threat detection rate and response time performance metrics demonstrating advancement from traditional to AI-enhanced security models

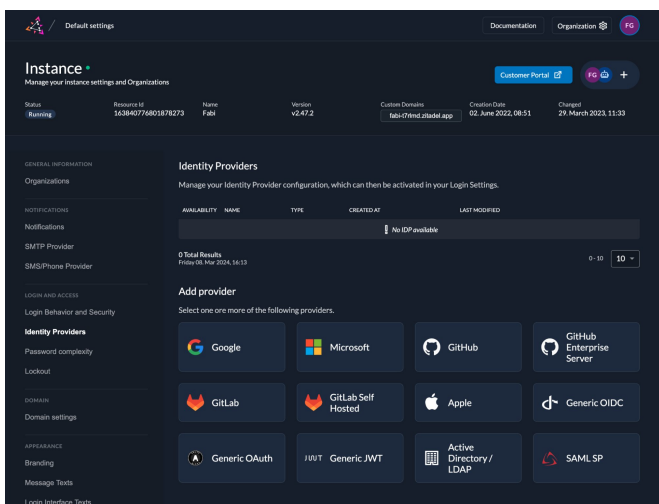


Fig. 6. Zitiel identity provider management interface displaying available authentication provider options and configuration settings

gle to see much beyond the perimeter walls. With ZTNA, every session gets followed closely, actions are watched moment by moment, while live data feeds better understanding. Smarter systems powered by artificial intelligence link separate alerts on their own, spotting odd patterns before they grow. Seeing more happens not just from watching harder but also from thinking ahead

Fig.5 shows how well various methods spot and react to threats. While old-style setups depend on fixed rules and known signatures, they tend to respond slowly and miss more. Instead of waiting, ZTNA checks users, devices, and access needs nonstop - on top of watching what users do. Because it learns patterns and acts fast, artificial intelligence pushes performance furthest, cutting delays through smart automation. Efficiency peaks here, where reactions start the moment danger appears.

Shown in Fig.6, the Zitiel identity provider dashboard serves as the core management tool in the described setup.

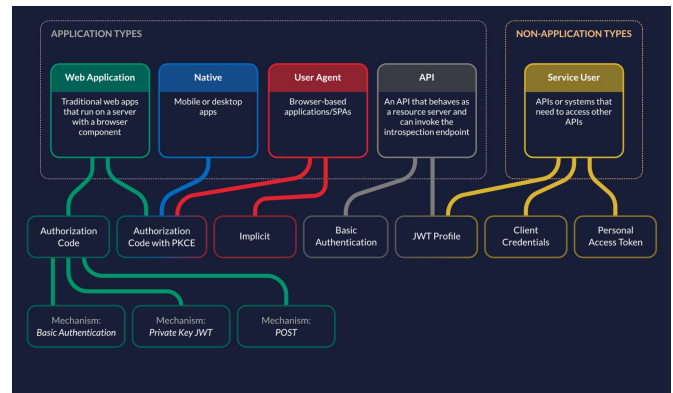


Fig. 7. Application type classification and corresponding authentication flow mechanisms including authorization code, PKCE, and JWT-based methods

While handling various login methods, it also centralizes user identity policies across systems. Security improves through reliable verification, yet adaptability comes from modular service links. Even under strict Zero Trust rules, access permissions remain easier to organize due to unified controls.

Shown in Fig.7, various app authentication pathways operate within the system - Authorization Code Flow, PKCE, along with JWT-driven approaches. Security improves through these means, as user-to-application interactions gain safeguards via reliable token handling, verified sessions, plus controlled access shaped by assigned roles inside the ZTNA model.

VI. CONCLUSION

The implementation of Zero Trust Network Access principles via Zitiel exemplifies a contemporary, identity-focused strategy for securing distributed applications. Continuous processes of authentication, authorization, and contextual verification are facilitated through Proof Key for Code Exchange-based authorization flows, ephemeral JSON Web Token tokens, multifactor authentication, and stringent policy enforcement, ensuring that only authenticated identities can access safeguarded resources. Geolocation verification, IP filtering, and token validation further enhance these security measures in the React frontend and Bun/Node.js backend, respectively. These protective mechanisms establish a multi-layered model that reduces the attack surface and eliminates dependence on conventional perimeter-based trust. Resilience is bolstered through containerized deployment, automated key rotation, and compatibility with enhancements such as security information and event management integration, along with advanced contextual policies. This approach mitigates risks linked to bespoke security implementations while managing OAuth 2.0 and OpenID Connect standards. The backend architecture is designed to accommodate additional verification layers without interfering with existing components, thus allowing for adaptation to changing threat environments. Collectively, these components form a practically applicable, highly scalable, and forward-compatible Zero Trust framework that functions efficiently within contemporary, decentralized digital ecosystems.

REFERENCES

- [1] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture," NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.
- [2] Fortinet, "What Is Zero Trust Network Access (ZTNA)?" Fortinet Cyber-glossary, 2024. [Online]. Available: <https://www.fortinet.com/resources/cyberglossary/what-is-ztna>
- [3] Cloudflare, "What is Zero Trust Network Access (ZTNA)?" Cloudflare Learning Center, 2024. [Online]. Available: <https://www.cloudflare.com/learning/access-management/what-is-ztna/>
- [4] Zscaler, "Zero Trust Network Access (ZTNA) – Benefits & Overview," Zscaler Security Terms Glossary, 2024. [Online]. Available: <https://www.zscaler.com/resources/security-terms-glossary/what-is-zero-trust-network-access>
- [5] Palo Alto Networks, "What Is Zero Trust Network Access (ZTNA)," Palo Alto Networks Cyberpedia, 2025. [Online]. Available: <https://www.paloaltonetworks.com/cyberpedia/what-is-zero-trust-network-access-ztna>
- [6] Palo Alto Networks, "What Is Microsegmentation?" Palo Alto Networks Cyberpedia, 2019. [Online]. Available: <https://www.paloaltonetworks.com/cyberpedia/what-is-microsegmentation>
- [7] Cloudflare, "What is microsegmentation?" Cloudflare Learning Center, 2024. [Online]. Available: <https://www.cloudflare.com/learning/access-management/what-is-microsegmentation/>
- [8] Zscaler, "What Is Microsegmentation?" Zscaler Security Terms Glossary, 2024. [Online]. Available: <https://www.zscaler.com/resources/security-terms-glossary/what-is-microsegmentation>
- [9] Microsoft, "Secure networks with SASE, Zero Trust, and AI," Microsoft Learn, 2025. [Online]. Available: <https://learn.microsoft.com/en-us/security/zero-trust/deploy/networks>
- [10] Balbix, "What Is Microsegmentation?" Balbix Insights, 2025. [Online]. Available: <https://www.balbix.com/insights/what-is-microsegmentation/>
- [11] Cato Networks, "What is Network Perimeter Security?" Cato Networks Glossary, 2025. [Online]. Available: <https://www.catonetworks.com/glossary/what-is-network-perimeter-security/>
- [12] Better Stack, "Authentication and Authorization with FastAPI: A Complete Guide," Better Stack Community Guides, 2025. [Online]. Available: <https://betterstack.com/community/guides/scaling-python/authentication-fastapi/>
- [13] Escape, "How to secure APIs built with FastAPI: A complete guide," Escape Blog, 2025. [Online]. Available: <https://escape.tech/blog/how-to-secure-fastapi-api/>
- [14] FastAPI, "Security - First Steps," FastAPI Documentation, 2025. [Online]. Available: <https://fastapi.tiangolo.com/tutorial/security/first-steps/>
- [15] Securonix, "Behavioral Analytics in Cybersecurity," Securonix Blog, 2024. [Online]. Available: <https://www.securonix.com/blog/behavioral-analytics-in-cybersecurity/>
- [16] CrowdStrike, "What Is Behavioral Analytics?" CrowdStrike Cybersecurity 101, 2025. [Online]. Available: <https://www.crowdstrike.com/en-us/cybersecurity-101/exposure-management/behavioral-analytics/>
- [17] Zscaler, "Behavioral Analytics in Cybersecurity: Boost Threat Detection," Zscaler Zpedia, 2024. [Online]. Available: <https://www.zscaler.com/zpedia/behavioral-analytics-in-cybersecurity-boost-threat-detection>
- [18] Splunk, "The Role of Behavioral Analytics in Cybersecurity," Splunk Blog, 2023. [Online]. Available: https://www.splunk.com/en_us/blog/learn/behavioral-analytics.html
- [19] AWS, "AWS Network Firewall introduces Geographic IP Filtering," AWS What's New, 2024. [Online]. Available: <https://aws.amazon.com/about-aws/whats-new/2024/08/aws-network-firewall-geoip-filtering/>
- [20] JumpCloud, "What is TOTP MFA?" JumpCloud Blog, 2022. [Online]. Available: <https://jumpcloud.com/blog/totp-mfa>
- [21] LoginRadius, "What is TOTP? Time-Based One-Time Password Explained," LoginRadius Blog, 2025. [Online]. Available: <https://www.loginradius.com/blog/engineering/what-is-totp-authentication/>
- [22] Twilio, "What is a Time-based One-time Password (TOTP)?" Twilio Documentation, 2015. [Online]. Available: <https://www.twilio.com/docs/glossary/totp>
- [23] Palo Alto Networks, "What Is Hybrid Cloud Security?" Palo Alto Networks Cyberpedia, 2022. [Online]. Available: <https://www.paloaltonetworks.com/cyberpedia/what-is-hybrid-cloud-security>
- [24] Check Point, "Understanding Hybrid Cloud Security," Check Point Cyber Hub, 2025. [Online]. Available: <https://www.checkpoint.com/cyber-hub/cloud-security/what-is-hybrid-cloud/>
- [25] Permit.io, "Best Practices for Implementing Hybrid Cloud Security," Permit.io Blog, 2024. [Online]. Available: <https://www.permit.io/blog/best-practices-for-implementing-hybrid-cloud-security>
- [26] Xenonstack, "Quick Guide for Anomaly Detection in Cybersecurity," Xenonstack Insights, 2022. [Online]. Available: <https://www.xenonstack.com/insights/cyber-network-security>
- [27] Techmagic, "Anomaly Detection AI: Benefits, Techniques, and Challenges," Techmagic Blog, 2025. [Online]. Available: <https://www.techmagic.co/blog/ai-anomaly-detection>